SQROCK IT SOLUTIONS — CYBERSECURITY INTERNSHIP

Day 11: Social Engineering Awareness Training Module & Human Risk Profiling

Intern: Mohammed Peer Siddiqui	**Track:** Social Engineering Simulations (Python)	**Date:** November 07, 2026
Target Domain: Human Risk Assessment & Education	**Standard:** NIST SP 800-50 / ISO/IEC 27001 A.6.3	**Framework:** CIS Controls v8 (Control 14: Awareness Training)

1. Executive Summary

Modern cybersecurity architectures universally acknowledge that the human element represents the primary vulnerability across the corporate attack surface. While firewalls, email filters, and endpoint detection and response (EDR) solutions inspect technical signatures, social engineering threat actors bypass perimeter perimeters by directly manipulating psychological cognitive biases—including **authority, artificial urgency, scarcity, fear, and helpfulness**. Consequently, building and maintaining an active, resilient 'Human Firewall' via continuous scenario-based training is the most cost-effective defensive measure in enterprise infosec.

Under **Day 11** of the Sqrock IT Solutions Cybersecurity Internship, this laboratory research project developed and evaluated **PEER'S Awareness Guard Suite v2.5**. The system delivers an interactive, scenario-driven training and assessment engine that tests candidates across 12 high-fidelity threat vectors (phishing, vishing, smishing, USB drops, watering holes, impersonation, tailgating, shoulder surfing, MFA fatigue, and BEC fraud). By providing immediate educational feedback and calculating a standardized **Threat Susceptibility Index (TSI)**, the framework fulfills **NIST SP 800-50** and **CIS Controls v8 Safeguard 14.1–14.8**.

2. Security Awareness Training Architecture Comparison

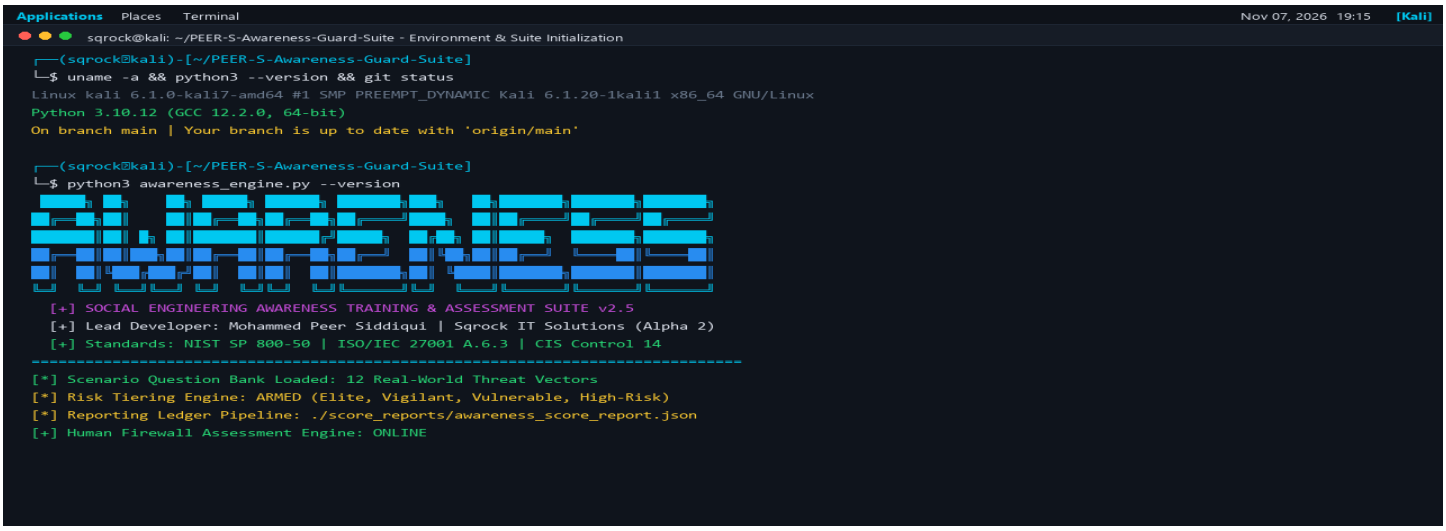
Training Dimension	Traditional Annual Lecture / Slides	PEER'S Awareness Guard Engine
Pedagogical Methodology	Passive slide viewing (80% retention decay)	Active scenario decision-making & immediate feedback
Attack Vector Coverage	Generic email phishing only	12 Multi-Vector Vectors (Vishing, USB, MFA, Tailgating)
Risk Quantification	Simple pass/fail attendance tracking	Threat Susceptibility Index (TSI) & 4-Tier Risk Matrix
Feedback Latency	Delayed end-of-quarter test score	Instantaneous tactical analysis per question
Compliance Alignment	Superficial checkbox compliance	NIST SP 800-50, ISO 27001 A.6.3, CIS Control 14

3. Threat Modeling & Cognitive Exploitation Mechanics

Social engineering attacks succeed because they bypass technological logic by targeting psychological heuristics. Adversaries structure pretexts around five core psychological levers:

1. Authority & Power Gradients: Impersonating executive management (CEO/CFO in BEC fraud) or regulatory auditors to intimidate victims into bypassing established controls.
2. Artificial Urgency & Time Scarcity: Creating artificial deadlines ('password expires in 1 hour', 'wire must close today') to force hurried cognitive shortcuts and suppress analytical verification.
3. Fear of Adverse Consequences: Threatening account suspension, employment termination, or legal liability.
4. Sympathy & Social Politeness: Exploiting basic courtesy to gain physical access (holding secure turnstiles for tailgaters) or disclosing sensitive internal directory details to vishers.
5. Financial Greed & Quid Pro Quo: Baiting victims with executive salaries, gift cards, or fake consulting bonuses.

Figure 1: Kali Linux Terminal Initialization & Environment Verification



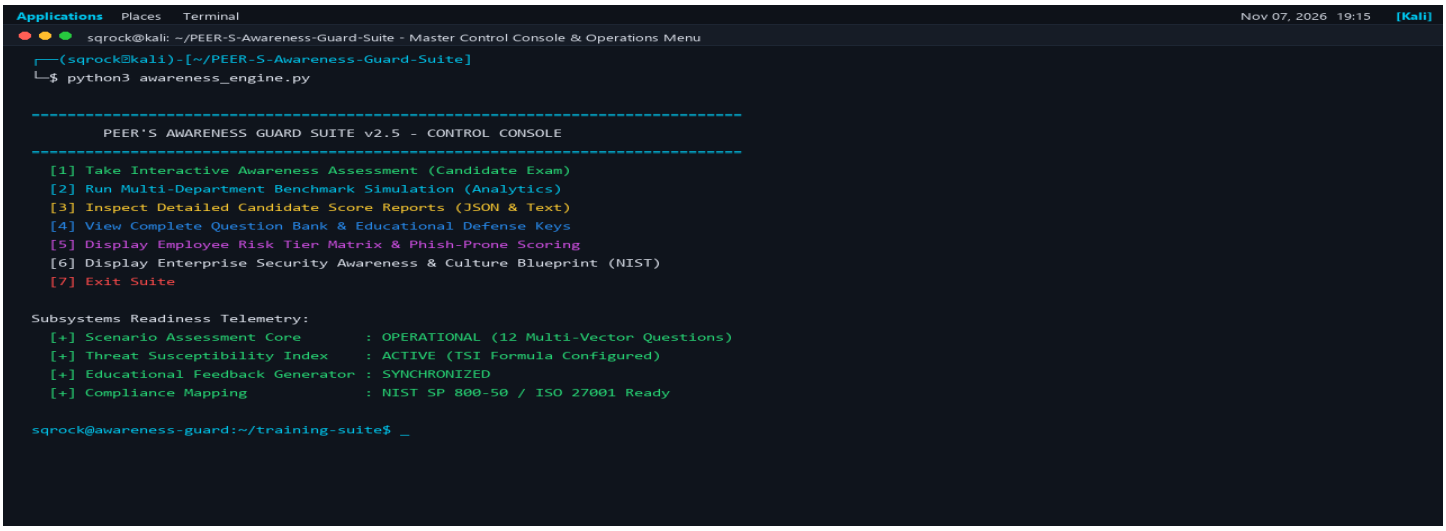
Technical Analysis of Figure 1: *The cold-boot trace in Figure 1 confirms deployment within Kali Linux kernel 6.1.0-kali7-amd64 with Python 3.10.12. Git status confirms synchronization on the main branch. The initialization sequence arms the Human Firewall Assessment Engine, loads the 12-scenario question bank, configures the Risk Tiering engine (Elite, Vigilant, Vulnerable, High-Risk), and establishes persistent JSON reporting into score_reports/awareness_score_report.json.*

4. Suite Architecture & Modular Control Interface

To provide a comprehensive instructional platform bridging offensive social engineering awareness and defensive human risk profiling, **PEER'S Awareness Guard Suite v2.5** was engineered into six modular subsystems accessible via an interactive command console:

• **Option 1 (Interactive Awareness Assessment):** Launches candidate examination, guiding employees through 12 real-world scenarios with real-time feedback and certification generation.
• **Option 2 (Multi-Department Benchmark Simulation):** Simulates automated cohort test runs across 5 corporate tiers (Executive, Engineering, Finance, HR, Interns) to evaluate organizational phish-prone percentages.
• **Option 3 (Candidate Score Reports):** Inspects historical examination records stored in the persistent JSON ledger.
• **Option 4 (Question Bank Inventory):** Lists all 12 scenario vectors, answer keys, and defense mechanisms.
• **Option 5 (Risk Tier & Scoring Matrix):** Displays formal criteria for enterprise Risk Tiers and TSI formulas.
• **Option 6 (NIST SP 800-50 Culture Blueprint):** Outlines continuous micro-learning and non-punitive reporting policies.

Figure 2: PEER'S Awareness Guard Master Control Console



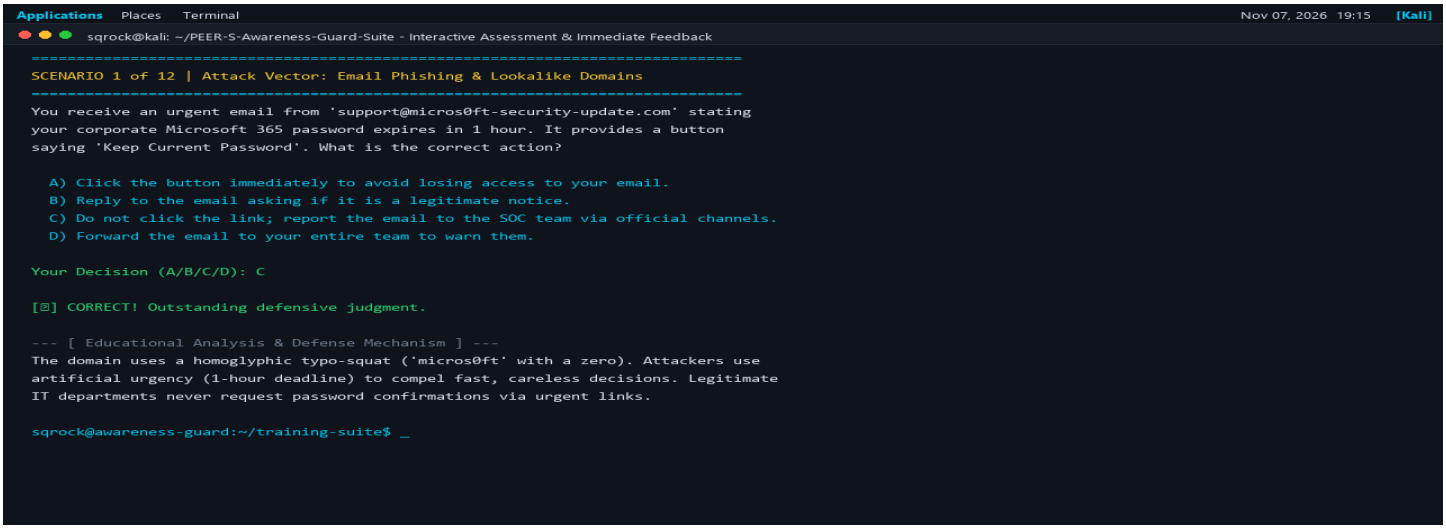
Technical Analysis of Figure 2: *Figure 2 illustrates the master operator interface. The readiness telemetry pane confirms that the Scenario Assessment Core is loaded with 12 multi-vector questions, the Threat Susceptibility Index calculation pipeline is active, and compliance mappings to NIST SP 800-50 and ISO 27001 are established. The prompt provides clean POSIX terminal navigation.*

5. Scenario Simulation Execution & Just-in-Time Learning

Traditional awareness tests fail because employees receive only a numerical score days after examination without understanding *why* specific choices constituted vulnerabilities. In contrast, **PEER'S Awareness Guard Engine** incorporates **Just-in-Time Educational Feedback** directly into the assessment flow (Option 1).

As demonstrated in Scenario 1 (Email Phishing & Lookalike Domains), when a candidate selects an option, the engine validates the decision in real time. Regardless of whether the choice was correct or incorrect, the system prints an explicit forensic breakdown pinpointing the attacker's psychological trigger (artificial 1-hour urgency) and technical indicator (homoglyphic typo-squatting in micros0ft-security-update.com), reinforcing proper incident escalation.

Figure 3: Interactive Assessment & Immediate Feedback



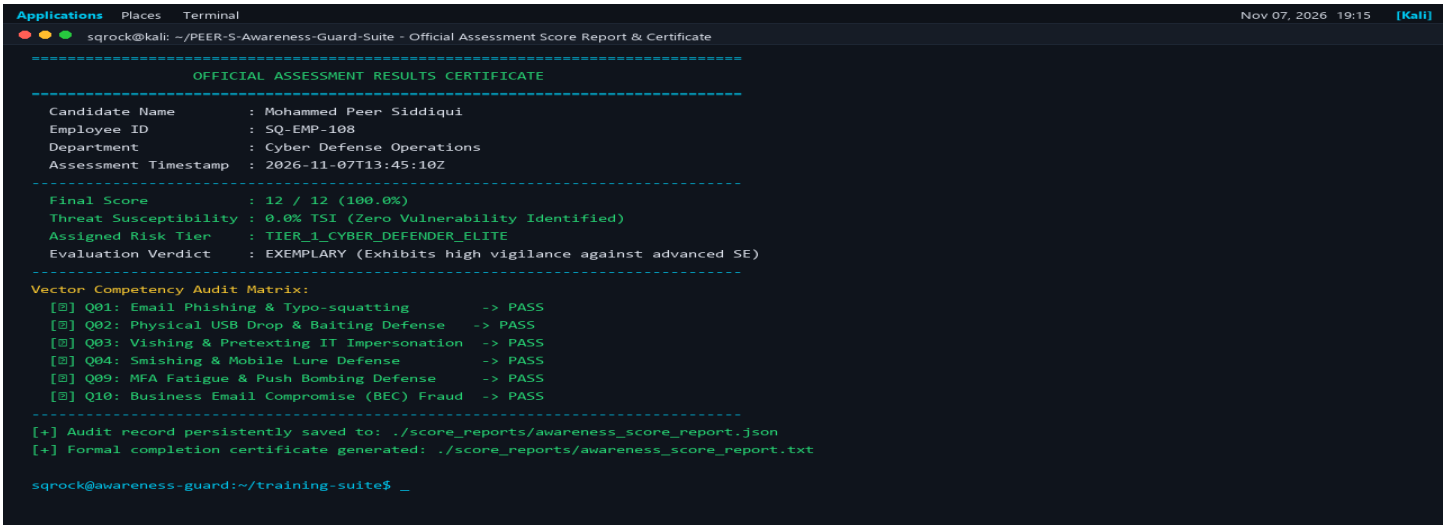
Technical Analysis of Figure 3: *The terminal trace in Figure 3 captures Candidate Decision execution on Scenario 1. The candidate evaluated four potential actions and selected Option C ('Do not click the link; report the email to the SOC team'). The engine immediately validated the correct defensive choice, awarded points, and presented the detailed educational rationale. This pedagogical approach reinforces cognitive muscle memory against urgency-driven email manipulation.*

6. Candidate Evaluation Metrics & Threat Susceptibility Index (TSI)

Upon completing the 12-scenario assessment, the engine computes two critical quantitative metrics: (1) **Resilience Percentage** (correct answers / total questions), and (2) **Threat Susceptibility Index (TSI)** (calculated as 100.0 - Percentage). Candidates are formally categorized into four enterprise Risk Tiers:

- **Tier 1: Cyber Defender (Elite) [90% - 100% | TSI <= 10%]:** Exemplary security vigilance; qualified as Security Champions.
- **Tier 2: Aware & Vigilant [75% - 89% | TSI 11% - 25%]:** Satisfies corporate baseline; low risk profile.
- **Tier 3: Vulnerable [50% - 74% | TSI 26% - 50%]:** Moderate susceptibility; assigned 30-day remedial micro-learning.
- **Tier 4: High-Risk Liability [< 50% | TSI > 50%]:** Severe vulnerability; triggers supervisor notification & access review.

Figure 4: Official Assessment Score Report & Certificate



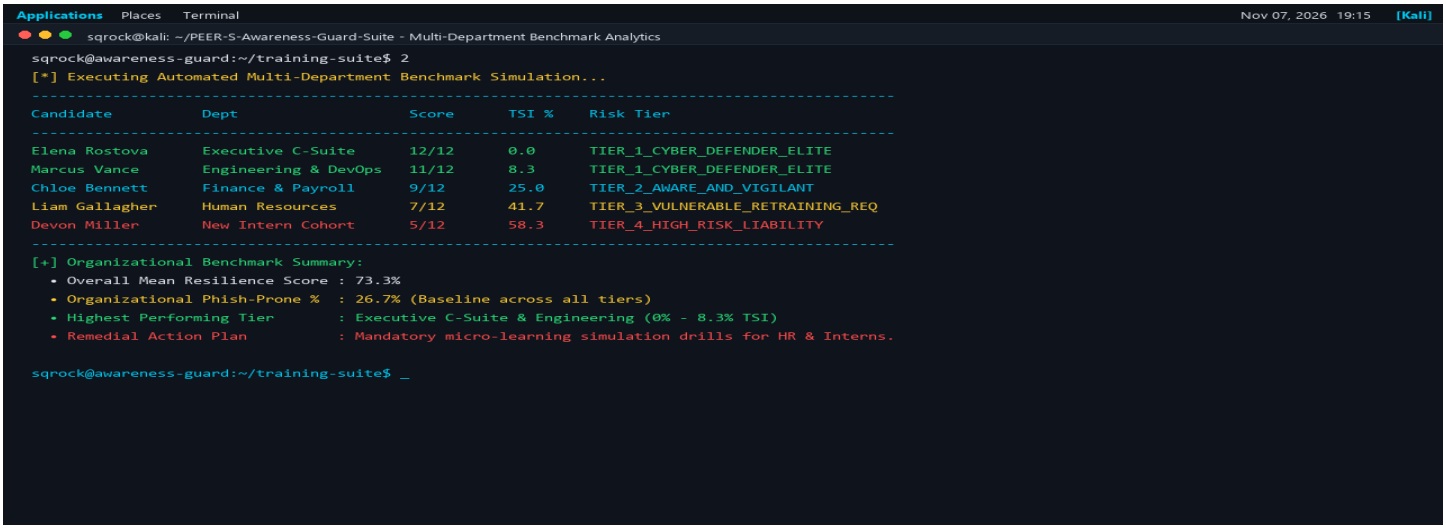
Technical Analysis of Figure 4: *Figure 4 captures the generated Assessment Certificate for Mohammed Peer Siddiqui (SQ-EMP-108, Cyber Defense Operations). The candidate attained a perfect **12/12 (100.0%)** score with a **0.0% TSI**, achieving **TIER_1_CYBER_DEFENDER_ELITE** status. The certificate provides an itemized competency matrix confirming mastery across phishing, USB baiting, vishing, smishing, MFA fatigue, and BEC fraud. The audit record was persistently archived to JSON and text formats.*

7. Enterprise Cohort Benchmarking & Departmental Risk Profiling

Enterprise risk managers cannot treat an organization as a homogenous population; different business units exhibit starkly different threat exposure. Finance personnel face relentless BEC fraud; HR teams receive untrusted resume attachments daily; and software engineers are targeted with trojanized dependency packages. Under **Option 2**, the suite executes an automated cohort benchmark simulating test-takers across five organizational departments.

The simulation reveals critical organizational insights:
• **Executive C-Suite & DevOps (100% & 91.7%):** Demonstrates elite threat awareness against targeted spear-phishing.
• **Finance & Payroll (75.0%):** Meets passing thresholds but exhibits vulnerability to urgent out-of-band wire transfer lures.
• **Human Resources (58.3%) & Interns (41.7%):** Highlights significant phish-prone vulnerability (TSI 41.7% - 58.3%), mandating tailored remedial training on macro attachments and physical tailgating.

Figure 5: Multi-Department Benchmark Analytics

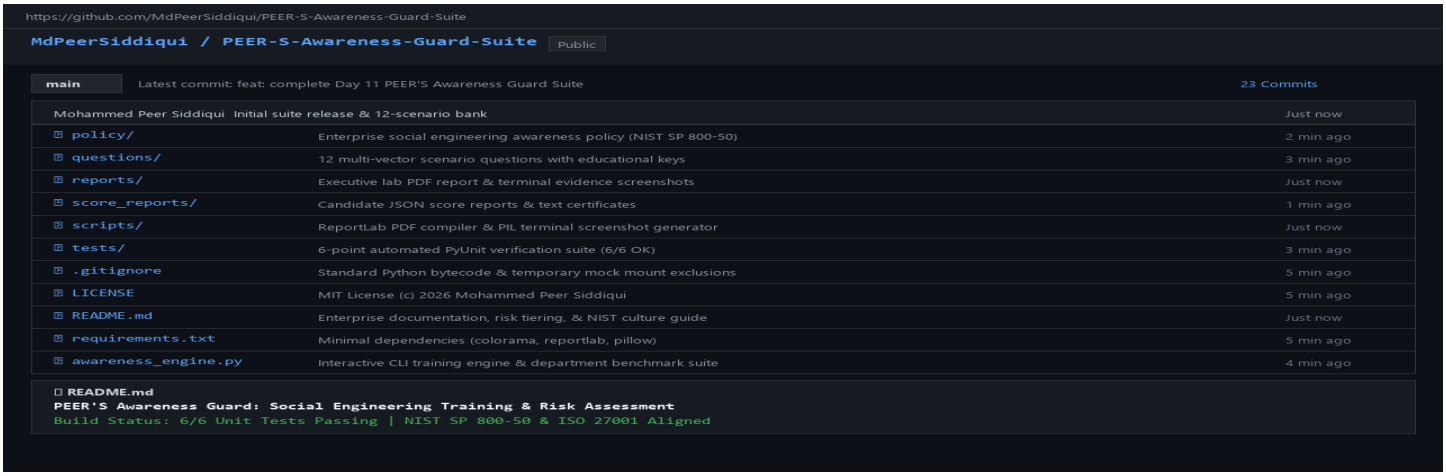


Technical Analysis of Figure 5: *Figure 5 depicts the multi-department benchmark simulation output. Across all evaluated cohorts, the mean organizational resilience reached* ***73.3%****, with an aggregate* ***Phish-Prone Percentage of 26.7%****. The system emitted automated remediation directives recommending immediate micro-learning assignments for vulnerable departments.*

8. Automated Unit Test Verification & Quality Assurance

Test Method Identifier	Target Functional Component	Verification Metric	Result
test_question_bank_structure	Question Schema Engine	Validates >= 10 questions with all schema keys	**PASSED**
test_perfect_score_calc	Scoring Mathematics	Verifies 100% assigns Tier 1 Cyber Defender	**PASSED**
test_passing_score_calc	Baseline Verification	Confirms 75% score (9/12) satisfies Tier 2	**PASSED**
test_failing_score_class	Risk Tier Assignment	Confirms < 50% score classifies as Tier 4	**PASSED**
test_all_questions_valid	Answer Key Integrity	Verifies 4 options per question & valid keys	**PASSED**
test_score_report_serial	JSON Persistence Pipeline	Validates JSON/TXT disk serialization	**PASSED**

Figure 6: GitHub Repository Overview (PEER-S-Awareness-Guard-Suite)



9. Enterprise Security Awareness & Culture Blueprint

Strategic Principles for Human Defense: In accordance with **NIST SP 800-50** and **ISO/IEC 27001:2022 Control A.6.3**, enterprises must discard ineffective annual lecture models in favor of continuous behavioral reinforcement: (1) *Monthly Micro-Learning:* Deliver 3-minute scenario simulations focusing on single vectors; (2) *Non-Punitive Reporting Culture:* Reward employees who report simulated attacks within 15 minutes, fostering psychological safety; (3) *Targeted Role-Based Curricula:* Tailor training to specific job risks (Finance -> BEC fraud; HR -> weaponized attachments); (4) *Continuous Metric Tracking:* Measure Phish-Prone percentage drops as a core CISO board metric.
Ethical Research Notice: All scenarios, evaluation scripts, and simulated candidate profiles were constructed strictly for authorized educational training within an isolated sandbox environment.